



Design Overview

Security Features and Implications



Dual AES-128 Encryption: Frames use channel-specific and global keys for layered encryption, allowing only provisioned decoders to decrypt.



Monotonic Timestamp Enforcement: Only increasing timestamps are accepted; prevents replay attacks and resets safely after reboots.

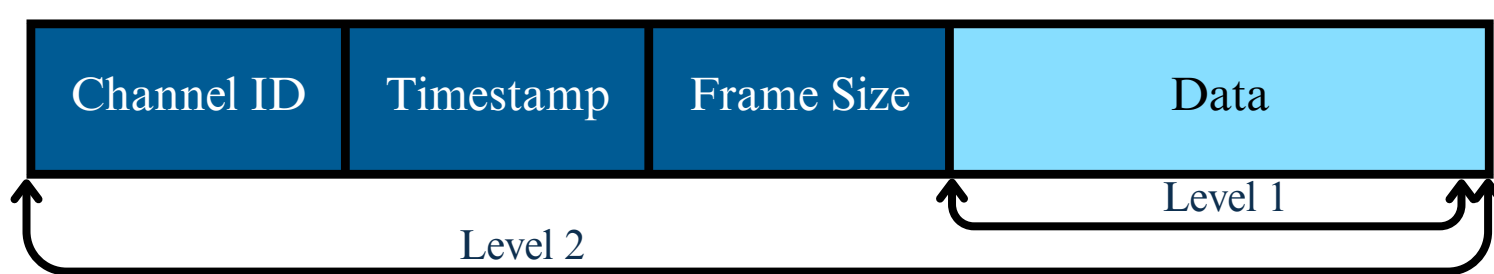


Timing Side-Channel Mitigation: Adds TRNG-based delay before decryption to defend against timing side-channel attacks.



Defensive Highlight

Two-layered AES-128 encryption



- Level 2 - decrypted using global master key
- Level 1 - decrypted using channel-specific key derived via $\text{channel_id} \% 10007$

Using two-layered encryption along with strict timestamp validation ensured maximum security against Expired Subscription and Replay attacks.

Mistakes:

- We used AES-ECB out of convenience
- Remember to include integrity checks!



First-Time Participant Lessons

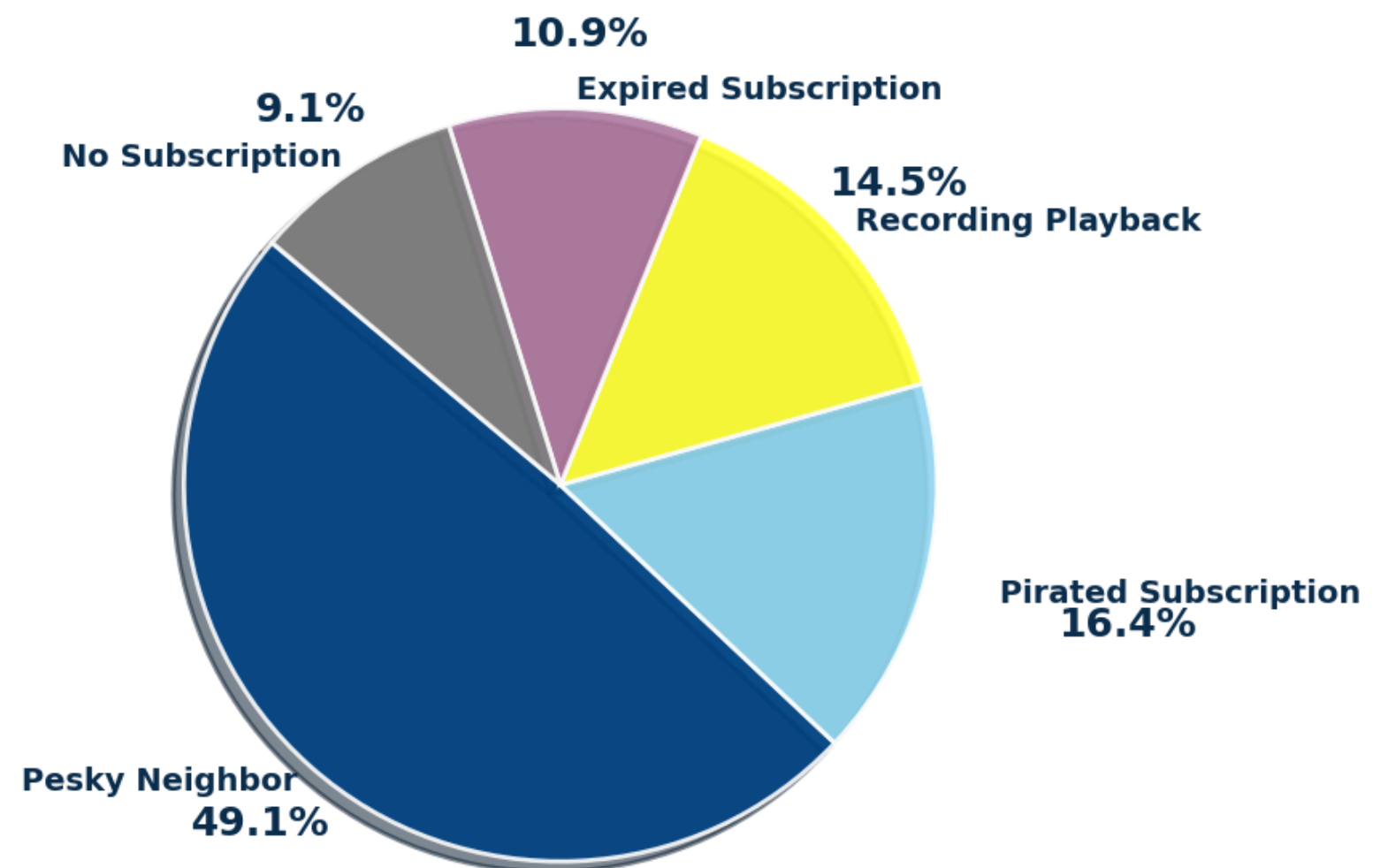
Technical Lessons:

- Focus on encryption both for attacks and defence
- Write test units for your defensive design
- Dedicate time to understanding the platform and tools before jumping in
- Automate scripts for attacks. We spent a lot of time manually running attacks

Strategic Lessons:

- Thoroughly review the MITRE EMB3D Threat Model
- Consider forming an interdisciplinary team, our team lacked the required expertise to launch hardware attacks within the competition's timeline
- Avoid rushing to the attack phase, we pushed ahead with a weak design to submit early in the attack phase

Flag Capture Distribution Analysis



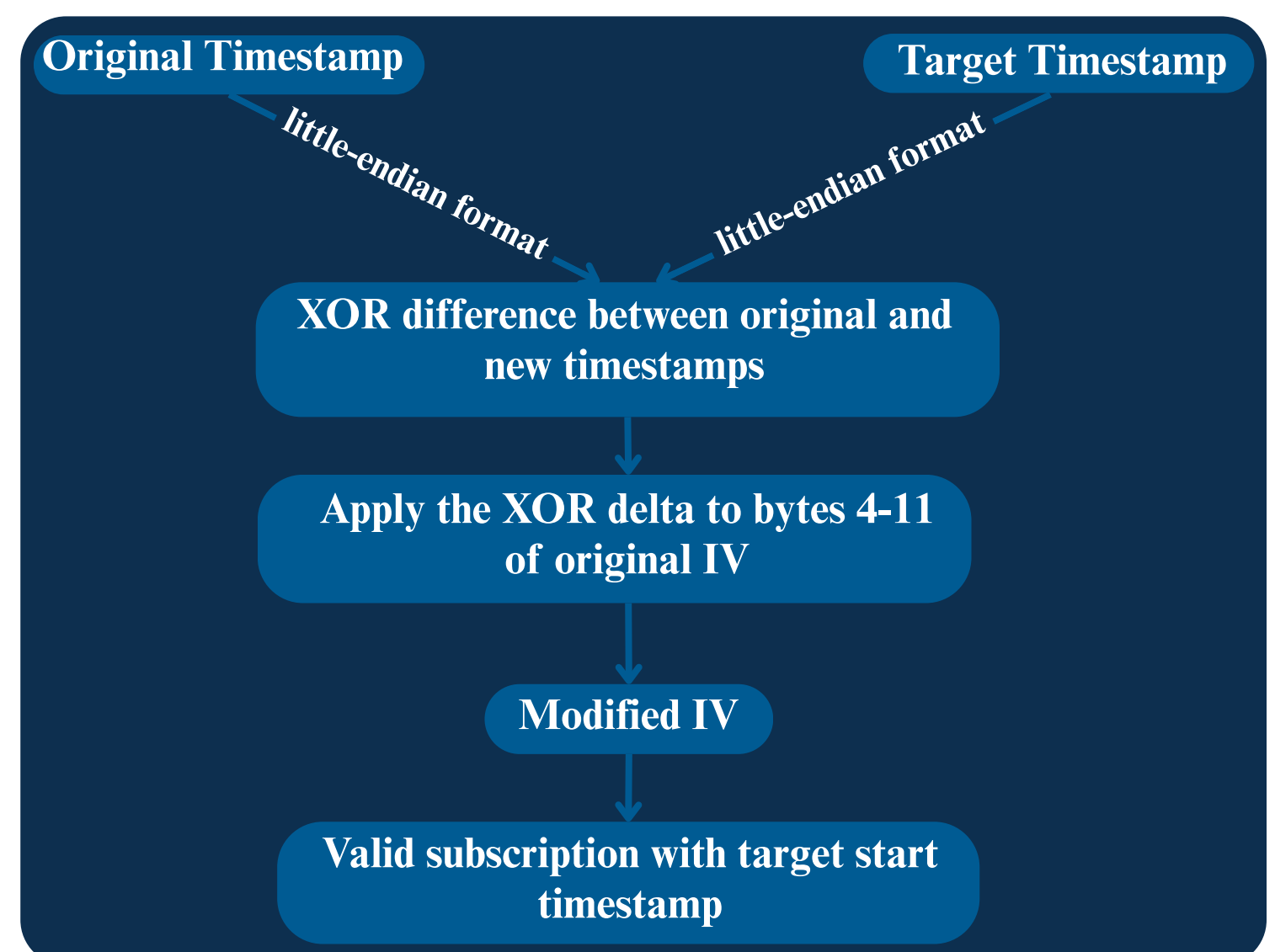
Offensive Highlight

Initialization Vector (IV) Tampering for Timestamp Manipulation

Vulnerability:

- Timestamps are in the AES-CBC encrypted subscription packet. AES-CBC encryption uses an IV that XORs each plaintext block with the previous ciphertext block.
- Manipulating the IV allows for direct alteration of the decrypted plaintext and a possibility of time stamp manipulation

Attack Method:



Result:

- **Recording Playback:** created a valid subscription with a lower start time
- **Expired Subscription:** For one design, missing authentication let us alter ciphertext, and changing the timestamp to higher value to read frames from channel two
- **Pesky Neighbor:** XORing the IV with 0x01 altered timestamps, breaking strictly increasing timestamp check

References

1. <https://www.nccgroup.com/us/research-blog/cryptopals-exploiting-cbc-padding-oracles/>